

VERIFICATION

Semgrep Integration — Verification Guide

Revision: 1

Last modified: 2026-06-21T00:00:00Z

Status: active

Constitution anchors: Universal — inheritable by every consuming project via the constitution submodule per §11.4.35.

Overview

This directory ships three scripts that install, provision on PATH, and validate Semgrep — a fast, open-source static analysis tool. The scripts follow the same patterns as the existing `codegraph_*.sh` family (§11.4.80): inherited by reference (never copied), POSIX-sh compliant per §11.4.67, anti-bluff validated per §11.4.69 / §107.

Semgrep is already available on this host at `~/.local/bin/semgrep` version 1.156.0 (installed via pip). These scripts make provisioning deterministic across any checkout.

File inventory

File	Purpose
<code>semgrep_setup.sh</code>	Checks for semgrep on PATH; installs via <code>pip --user</code> (fast path) or builds from the <code>git@github.com:semgrep/semgrep.git</code> submodule source when the OCaml toolchain is available. Logs every install event to <code>docs/semgrep/Status.md</code> .
<code>semgrep_path.sh</code>	Source-able snippet for <code>.bashrc</code> / <code>.zshrc</code> that adds common binary directories to PATH (idempotent — no duplicates).

File	Purpose
semgrep_validate.sh	Anti-bluff validation functions: runs semgrep scan --config auto --json against a real C fixture file and asserts valid JSON output with a results key; also verifies the semgrep registry is reachable via --dump-config-rules.
VERIFICATION.md	This document — the companion user guide per §11.4.18.

Installation paths

1. pip install (recommended, fast path)

```
. <constitution>/scripts/semgrep/semgrep_setup.sh  
semgrep_setup_install
```

Requires python3 and pip3. Installs to ~/.local/bin/semgrep.

2. Build from source (OCaml)

```
. <constitution>/scripts/semgrep/semgrep_setup.sh  
semgrep_setup_build
```

Requires ocaml, opam, make, gcc. Clones git@github.com:semgrep/semgrep.git into submodules/semgrep/ if not already present; falls back to pip if the OCaml toolchain is missing or the build fails.

3. Check-only

```
. <constitution>/scripts/semgrep/semgrep_setup.sh  
semgrep_setup_check
```

Exits 0 if semgrep is on PATH and functional, non-zero otherwise.

System PATH integration

Add the following to ~/.bashrc or ~/.zshrc:

```
# s emgrep PATH integration (constitution)  
if [ -f "<constitution>/scripts/semgrep/semgrep_path.sh" ]; then  
    . "<constitution>/scripts/semgrep/semgrep_path.sh"  
fi
```

The script adds the following directories to PATH if they exist and aren't already present: ~/.local/bin, ~/.cargo/bin, /usr/local/bin, /opt/homebrew/bin, ~/bin.

Anti-bluff validation protocol

Run the validation suite directly:

```
bash <constitution>/scripts/semgrep/semgrep_validate.sh
```

This executes two checks:

1. **semgrep_validate_check** — runs `semgrep scan --config auto --json` on a bundled C test fixture (`docs/.semgrep/test_fixture.c`), asserts the output is valid JSON (parsed via `python3 -m json.tool`), and writes the scan JSON to `docs/.semgrep/scan_<ts>.json` as captured evidence.
2. **semgrep_validate_rules** — runs `semgrep --config-registry --dump-config-rules (head -5)` to verify the registry is reachable, writing output to `docs/.semgrep/registry_<ts>.txt`.

Every PASS emits a structured line matching the §11.4.69 `ab_pass_with_evidence` pattern:

```
PASS: semgrep scan produced valid JSON with results [evidence: docs/.semgrep/scan_20260621T120000Z.json]
```

Failures are logged to `docs/semgrep/Status.md` with ISO timestamps.

docs_chain context wiring

When the `docs_chain` engine (§11.4.106) is wired, the `semgrep` Status documents at `docs/semgrep/Status.md` and `docs/semgrep/Status_Summary.md` (both created automatically by the setup and validate scripts on first invocation) are registered as a roster-backed context:

```
# .docs_chain/contexts/semgrep.yaml
context: semgrep
source:
  - docs/semgrep/Status.md
  - docs/semgrep/Status_Summary.md
fingerprint: sha256
export:
```

- [html](#)
- [pdf](#)

Usage in consuming projects

A project that inherits this constitution submodule can wire semgrep into its pre-build gate or setup script:

```
# In scripts/setup.sh (post-clone bootstrap)
. <constitution>/scripts/semgrep/semgrep_setup.sh
semgrep_setup_install

# Run validation
bash <constitution>/scripts/semgrep/semgrep_validate.sh
```

Recommended pre-build gate: CM-SEMGREP-INSTALLED (verifies semgrep --version returns a non-empty string and semgrep_validate_check passes).

Edge cases

Scenario	Behaviour
pip not installed	semgrep_setup_install exits 2 with a clear error message.
pip install OK but binary absent	Post-install version check catches the bluff — exits 1.
OCaml build fails	Falls back to pip install (graceful degradation).
Network unreachable	Both install and registry-validate detect and log the failure.
semgrep already on PATH	semgrep_setup_check returns 0 — no-op.
Empty scan output	Anti-bluff detects non-JSON / missing results key — FAIL.

Cross-references

- §11.4.69 — Universal sink-side positive-evidence taxonomy (ab_pass_with_evidence pattern)
- §11.4.80 — CodeGraph regular-update + sync automation (sibling pattern)
- §11.4.106 — docs_chain mechanical sync engine

- §11.4.67 — Shell-script target-shell-parseability (POSIX-sh compliance)
- §11.4.18 — Script documentation mandate (this document)
- constitution/scripts/codegraph_update.sh — sibling update script pattern